

Technical Case Study: Cyber Attack Analysis

Student Name: Shaked Sarbstein

Date: 14.06.2026

Chosen Cyber Technique: Man-in-the-Middle – Evil Twin / Rogue AP (MITRE ATT&CK T1557, T1040, T1071)

Selected Cyber Attack / Campaign: DarkHotel - hotel Wi-Fi

Scope note: DarkHotel's signature evil-twin / rogue-AP hotel campaign was disclosed by Kaspersky in 2014 and was most active c. 2010–2015 – outside the workshop's 2021–2026 window. It is presented here as the canonical real-world evil-twin / MITM case because it most directly matches our chosen attack category; the group remained active with later (non-evil-twin) operations through 2020+. Confirm acceptability with the instructor before final submission.

1. Case Overview

Attribute	Details
Attacker / Threat Actor	DarkHotel APT - a long-running cyber-espionage group, assessed by several vendors as North Korea-linked.
Victim / Target Org.	Senior business executives (C-level, VP, sales/marketing, R&D) in defense, pharmaceutical, electronics, energy and government sectors, while staying at luxury hotels – mainly in the APAC region.
Attack Timeline	C&C connections traced to ~2009; peak hotel activity Aug 2010–2013, first detected by Kaspersky Jan 2014; 2014–2015 campaign against international travellers; shifted to spear-phishing / 0-days from 2015 onward.
Overall Impact & Damage	Thousands of devices potentially compromised over the campaign's lifetime; targeted theft of credentials and intellectual property / espionage data from high-value individuals. Highly selective – only chosen targets were infected.

2. Technical Attack Architecture & Technique Execution

- **Initial Access Vector:** the group compromised the hotel's network infrastructure – wireless access points and the captive-portal / gateway systems – via remote exploitation or social engineering of hotel IT staff. This gave them a man-in-the-middle position over all guest traffic.

Mechanics of the Evil Twin / MITM technique

- Once in the MITM position, when a guest opened a browser the attackers injected content into the session, redirecting the victim to attacker-controlled pages (effectively DNS/traffic hijacking from the compromised gateway).
- The victim was shown a fake “software update” prompt – a trojanised installer disguised as a legitimate update from vendors such as Adobe Flash or Google, signed with **forged / stolen digital certificates** to appear authentic.
- Target selection used the hotel **check-in data** (guest surname + room number): only the intended high-value target received the malicious payload, while ordinary tourists were passed through to the normal internet – minimising exposure and detection.
- Exploited vulnerabilities over the campaign's life included Internet Explorer / Adobe Flash zero-days, e.g. **CVE-2014-0497 (Flash)**, **CVE-2018-8373 (VBScript engine)**, and later IE/JScript zero-days (CVE-2020-1380, “Operation PowerFall”, low-confidence attribution). Stolen code-signing certificates kept the malware under detection thresholds.

Attack Flow

1. Compromise the luxury-hotel gateway / captive portal and rogue AP infrastructure.
2. Guest connects to the (now attacker-controlled) hotel Wi-Fi and authenticates with surname + room number.
3. Cross-reference the login against check-in data to confirm the target is a high-value individual.
4. On first browsing, inject a fake “security / software update” page served from an attacker server.
5. Victim installs the signed trojan → backdoor + keylogger deployed → credentials and espionage data exfiltrated to C&C.

3. Detection Analysis

A. Historical Detection (how it was detected)

- **Detected by** Kaspersky GReAT in January 2014, triggered by automated telemetry showing a cluster of customer infections that were traced back to the networks of specific Asian hotels – not by the hotels or victims themselves.
- **Long dwell time:** C&C activity dated back to 2009, so the operation ran undetected for years. Honeypot machines brought into the hotels by researchers were deliberately *not* attacked, confirming the highly selective targeting that helped it evade discovery.

B. Proactive Detection (how it could have been caught by AI/ML IDS)

- **Signature / IoC:** revoked/forged code-signing certificates (e.g. the Xuchang Hongguang cert), known C&C domains and malicious .hta/.rar droppers using the RTLO file-extension trick could be flagged via YARA / IDS signatures.
- **Behavioural / anomaly (the evil-twin angle):** a WIDS/ML model on 802.11 + gateway telemetry could flag rogue-AP indicators – duplicate SSID with a different BSSID/MAC, abnormal signal strength, captive-portal/DNS responses that differ from baseline, and unexpected HTTP redirects or injected “update” pages.
- **Log sources required:** wireless frame captures (radiotap/802.11 management frames), DHCP/DNS logs, gateway HTTP proxy logs, and endpoint logs for unsigned-but-“signed” update execution (e.g. process creation of fake updaters).

4. Key Takeaways & Mitigation

- **Primary Mitigation:** always use a VPN on hotel / public Wi-Fi; treat in-network “software update” prompts as hostile and only update over trusted networks via vendor channels; enforce code-signing verification and certificate pinning; segment and harden hotel gateway/AP management.
- **Lessons for Intrusion Detection:** signature-only IDS missed DarkHotel for years because of stolen certificates and selective targeting. This motivates our project: an ML/DL evil-twin detector on 802.11 features (rogue-AP signal/MAC/protected-frame anomalies) plus an LLM triage layer that can reason over injected-content and certificate anomalies, catching exactly the “low-and-slow, highly selective” behaviour that defeated traditional defences.

5. References

- Kaspersky GReAT, “The Darkhotel APT: A Story of Unusual Hospitality,” Securelist, 2014. <https://securelist.com/the-darkhotel-apt/66779/>
- Kaspersky, “Darkhotel’s attacks in 2015 (Hacking Team Flash 0-day, CVE-2014-0497),” Securelist / Kaspersky blog, 2015.
- Threatpost / Trend Micro & Qihoo 360, “Darkhotel exploits Microsoft VBScript zero-day CVE-2018-8373,” 2018.
- Kaspersky, “Operation PowerFall: IE & Windows zero-days (CVE-2020-1380, CVE-2020-0986),” Securelist, 2020 (low-confidence DarkHotel attribution).
- MITRE ATT&CK, Group G0012 (Darkhotel) and Technique T1557 (Adversary-in-the-Middle). <https://attack.mitre.org/groups/G0012/>